

PDF文档三：开通/回收权限等高风险变更（详细版）

文档编号：IT-CHG-003

版本：V2.0

密级：内部敏感

生效日期：2026-08-14

1. 目的

规范权限开通、回收及其他高风险变更操作，建立变更申请、风险评估、审批、实施、验证、回退、审计的全流程管控机制，确保变更过程受控、可审计，降低安全与业务风险。

2. 适用范围

适用于公司所有信息系统、网络设备、应用平台、数据库、云资源、安全设备等的权限开通、回收、角色调整、特殊权限授予、防火墙策略变更、管理员账号管理等高风险变更。

3. 术语定义

- 高风险变更**：可能导致数据泄露、业务中断、越权访问、合规违规或影响范围广的变更操作。
- 权限开通**：为用户或系统账号增加新的访问或操作权限。
- 权限回收**：减少或取消用户已拥有的访问或操作权限。
- 权限最小化**：仅授予完成工作所需的最小权限，避免过度授权。
- 双人复核**：由两名管理员分别操作与验证，防止单人误操作或恶意操作。
- 变更窗口**：预先批准的适合实施变更的时间段，通常为业务低峰期。
- 回退方案**：变更失败或引发异常时，恢复到变更前状态的详细步骤。

4. 高风险变更定义与范围（详细）

以下变更视为高风险，必须遵守本流程：

4.1 权限类

- 核心业务系统（如ERP、财务、CRM、客户数据平台）的权限开通、回收、角色调整
- 数据库、域控、云平台、虚拟化平台管理员权限的开通或回收
- 批量权限变更（一次涉及 ≥ 10 个账号或 ≥ 5 个系统）
- 离职、转岗人员的权限回收（含账号禁用、数据移交）
- 外部人员、第三方厂商、临时账号的权限授予与续期
- 特权账号（如root、administrator、系统默认账号）的创建、修改、删除

4.2 安全策略类

- 防火墙策略变更、VPN权限调整、安全组规则修改
- 入侵检测/防御系统规则变更
- 数据防泄漏策略调整
- 加密策略、密钥变更

4.3 系统配置类

- 核心业务系统配置参数修改
- 数据库结构变更、存储过程修改
- 云资源升降配、网络拓扑调整
- 补丁安装、版本升级（影响核心业务）

5. 职责分工

角色	主要职责
申请人	提出变更需求，确保信息准确、理由充分
业务主管	审批变更的必要性与业务合理性
信息安全官	评估安全风险，审批敏感权限变更
变更经理（可选）	协调变更计划、窗口、资源，监督流程
系统管理员	按批准工单实施变更，执行双人复核
审计人员	定期审计变更记录与权限现状
用户/受影响方	配合验证变更结果，反馈异常

6. 变更管理原则

-
- 先审批后实施：**未经批准，任何人不得进行高风险变更。
 - 最小权限：**授予权限不得超过岗位职责所需。
 - 职责分离：**申请人、审批人、实施人不得为同一人。
 - 双人复核：**高风险变更须由两名管理员操作与复核。
 - 全程留痕：**变更申请、审批、实施、验证均须记录。
 - 可回退：**所有高风险变更必须有回退方案。
 - 变更窗口：**核心系统变更尽量安排在业务低峰期。

7. 权限开通/回收流程（详细）

7.1 申请与业务审批

申请人填写《权限变更申请单》，包含：

- 申请人、申请日期、变更类型（开通/回收/调整）
- 目标用户（工号、姓名、部门）
- 目标系统与模块
- 申请权限类型与具体范围

- 变更理由（如入职、转岗、项目需要、离职）
- 期望生效日期与有效期（临时权限须注明）
- 是否涉及敏感数据

业务主管审批要点：

- 权限是否与岗位职责匹配
- 是否满足最小权限原则
- 临时权限是否有明确期限

7.2 安全/合规复核

涉及以下情况时，须信息安全官复核：

- 敏感系统、管理员权限、批量变更
- 外部人员权限授予
- 离职人员权限回收（复核是否彻底）
- 权限范围超出岗位常规需求

复核内容包括：

- 权限是否超出职责、是否存在冲突或风险
- 是否满足合规要求（如SOX、等保）
- 是否有可回退方案

7.3 变更实施

- 系统管理员根据批准后的工单执行变更
- 禁止在未取得审批的情况下提前操作
- 实施时须截图或记录变更前后状态
- 高风险变更必须双人操作：一人操作，一人复核
- 实施过程中如遇异常，立即停止并报告

7.4 验证与确认

- 实施后，由申请人或用户验证权限是否生效、业务是否正常
- 管理员确认无异常后，关闭变更工单
- 验证结果记录在工单中，包括：验证人、时间、结果、截图

7.5 回退与应急

- 若变更引发故障或安全事件，立即启动回退方案
- 回退操作同样需双人复核，并记录回退时间、操作人、结果
- 重大故障按《知识咨询/IT故障排查说明》升级处理

7.6 关闭与记录

- 变更工单关闭后，相关记录自动归档
- 权限变更记录应至少保存3年
- 离职人员权限回收工单需在员工离职手续中闭环

8. 高风险变更特别要求（详细）

8.1 双人操作

- 关键系统权限变更须两人在场或系统二次审批
- 操作人与复核人不得为同一人，复核人须具备同等技术能力
- 复核内容包括：变更对象、权限范围、生效时间、回退准备

8.2 灰度实施

- 批量变更建议分批次执行，先小范围验证
- 例如：批量回收权限，先处理5个账号，确认无异常后再处理剩余账号
- 灰度结果记录在工单中

8.3 变更窗口

- 核心系统变更尽量安排在业务低峰期（如周五晚间、周末）

- 变更窗口须提前通知相关部门
- 紧急变更可不受窗口限制，但须事后补审

8.4 通报机制

- 影响范围大的变更需提前通知相关部门
- 通知内容：变更时间、影响范围、预计时长、联系人
- 变更完成后，及时通报结果

8.5 定期复核

- 每季度对重要系统权限进行复核，清理冗余或过期权限
- 复核范围：管理员账号、外部账号、临时账号、离职人员残留权限
- 复核结果形成《权限定期复核记录表》，由信息安全官签字确认

9. 审计与考核

9.1 审计频率

- 信息安全与审计部门每月抽查高风险变更工单，核对审批与实施一致性
- 抽查比例不低于当月变更总量的20%
- 每季度进行一次权限专项审计

9.2 审计内容

- 变更是否经过完整审批
- 实施内容与审批内容是否一致
- 是否执行双人复核
- 是否有回退方案
- 变更记录是否完整、可追溯

9.3 考核与处理

- 将权限管理合规性纳入相关部门绩效考核
- 对未审批变更、越权操作、记录缺失等行为，按公司制度处理
- 造成严重后果的，追究法律责任

10. 附件表单

- 《权限变更申请单》
- 《高风险变更审批表》
- 《权限定期复核记录表》
- 《变更回退记录表》
- 《变更通知模板》